Active Directory Migration

Purpose of AD Domain Migration

Active Directory (AD) is the heart of a Windows network. Over time, the servers that run it get old, the company grows, or the structure no longer fits the business. **AD migration** means moving AD (domain controllers, users, groups, computers, policies) to a new server platform or a new domain structure with **minimum disruption**.

Common reasons:

- **Upgrade** old domain controllers (for example Windows Server 2012 / 2016 / 2019) to a newer, supported and more secure version (2022 / 2025).
- **Hardware or data center change:** moving to new hardware, a virtual platform or the cloud.
- **Company mergers and acquisitions:** combining or separating domains and forests.
- **Restructuring or consolidation:** reducing the number of domains, cleaning OUs, renaming the domain.
- **Security and compliance:** retire legacy protocols, enable modern security features.
- **Performance and reliability** improvements.

Types of AD Migration

Type	Description	When used
In-place upgrade	The operating system of the existing domain controller is upgraded directly (e.g., 2016 → 2022).	Small environments; has risk and is generally **not recommended** for domain controllers.
Swing / side-by-side migration (DC replacement)	Install new domain controllers with the new OS, add them to the existing domain, move roles, then demote the old ones.	**Best practice** for upgrading the domain controller OS in the same domain. This is what you do for 2019 → 2022.
Intra-forest (cross-domain) migration	Move users, groups and computers between domains inside the same forest (using ADMT with SID history).	Domain consolidation or restructuring
Inter-forest migration	Move objects between different forests (often with trust relationship).	Mergers, acquisitions, separating a company
Cloud / hybrid migration	Extend or migrate to Microsoft Entra ID (Azure AD) or Entra Domain Services.	Moving to Microsoft 365 or cloud-first strategy

> **Tool: ADMT (Active Directory Migration Tool)** is Microsoft's tool for cross-domain and cross-forest migration (users, groups, computers, passwords and SID history). Upgrading DCs within the same domain does not need ADMT.

FSMO Roles Migration

In every AD forest there are **five FSMO (Flexible Single Master Operations) roles**. Most changes in AD can be made on any DC (multi-master), but these special tasks are done by only one DC at a time to avoid conflicts.

FSMO role	Scope	Function
Schema Master	One per forest	Controls changes to the AD schema (the definition of object types and attributes)
Domain Naming Master	One per forest	Adds or removes domains in the forest
PDC Emulator	One per domain	Time synchronization source, password changes and lockouts, GPO editing preference; the most "busy" role
RID Master	One per domain	Hands out blocks of Relative IDs to DCs, used to create unique SIDs for new objects
Infrastructure Master	One per domain	Updates cross-domain object references (group membership of users from other domains)

Transfer vs seize

- **Transfer:** a clean, planned move of the role while both DCs are online. Use this in a migration.
- **Seize:** forcing a role onto another DC when the original is permanently dead. After seizing, the old DC must **never** be brought back online on the network (rebuild it instead).

How to view and move FSMO roles

```
netdom query fsmo                        # show which DC holds each role

Get-ADDomain | Select PDCEmulator, RIDMaster, InfrastructureMaster

Get-ADForest | Select SchemaMaster, DomainNamingMaster

Move-ADDirectoryServerOperationMasterRole -Identity "NEWDC" -OperationMasterRole
0,1,2,3,4   # transfer all five
```

In the PowerShell command the numbers mean: 0 = PDCEmulator, 1 = RIDMaster, 2 = InfrastructureMaster, 3 = SchemaMaster, 4 = DomainNamingMaster. The roles can also be moved with the GUI snap-ins (AD Users and Computers, AD Domains and Trusts, Schema snap-in) or with **ntdsutil**.

Preparation Steps for Migration

1. **Plan and scope:** define goals, timeline, the maintenance window and a rollback plan; get management approval.

2. **Inventory:** list all DCs, their roles, OS versions, IPs, sites; list dependent systems (DHCP, DNS, file servers, applications using LDAP, NPS, CA, Exchange).
3. **Check AD health on the existing environment:** `dcdiag /v`, `repadmin /replsummary`, `repadmin /showrepl`. Fix all errors first. DNS must be healthy.
4. **Check SYSVOL replication method:** if the domain still uses the old **FRS**, migrate to **DFSR** before adding new-OS controllers.
5. **Verify functional levels** and prerequisites for the new OS version.
6. **Take full backups, including System State backups** of at least two DCs, and test that they can be restored.
7. **Document** current FSMO holders, IP addresses, DNS settings, and DHCP scopes.
8. **Prepare the new server:** install the OS, patch it, set a static IP, name it, and join it to the domain.
9. **Communicate** to users and application owners about the change window.

Key Migration Steps

This is the usual **swing migration** sequence for replacing old domain controllers with new ones:

1. **Install the AD DS role** on the new server (Server Manager → Add Roles and Features).
2. **Promote the server to a domain controller** in the existing domain (select "Add a domain controller to an existing domain"). During the wizard the schema is automatically prepared if you use an account that is a member of Schema Admins and Enterprise Admins (or run `adprep /forestprep` and `adprep /domainprep` manually from the installation media).
3. Enable **DNS Server** and **Global Catalog** on the new DC (normally selected by default).
4. **Wait for replication** and verify with `repadmin /replsummary` and `dcdiag`.
5. **Transfer the FSMO roles** from the old DC to the new DC.
6. **Update DNS settings:** make the new DC the primary DNS server for clients, servers and DHCP scope options; update forwarders; check that the old DC's records can be removed later.
7. **Move other services** that run on the old DC (DHCP, certificate authority, file shares, NPS, etc.) to the new server, or confirm they are not on DCs.
8. **Update applications** or devices that point to the old DC's name or IP for LDAP / authentication (printers, firewalls, Linux, VPN).
9. **Run in parallel for some days** and monitor errors in the Event Viewer (Directory Service, DNS Server, DFS Replication logs).
10. **Demote the old DC:** in Server Manager remove the AD DS role (or use `Uninstall-ADDSDomainController`), then remove the server from the domain and decommission it.
11. **Clean up metadata:** remove the old DC's leftover entries from AD Sites and Services, DNS and the metadata (only if the demotion was not clean).
12. **Raise the domain and forest functional level** if all DCs support it.

Post-Migration Validation

- Run `dcdiag /v` on every DC; all tests should pass.
- Run `repadmin /replsummary` and `repadmin /showrepl`: zero failures, low latency.
- Confirm the **FSMO role holders** with `netdom query fsmo`.
- Test **DNS resolution** (`nslookup`), and that SRV records for the new DC exist.
- Verify the **SYSVOL and NETLOGON shares** exist and that GPOs are replicated and applied (`gpupdate /force`, `gpresult /r`).
- Test **user logon**, domain join, password change, and Kerberos authentication from clients.
- Check time synchronization (PDC Emulator syncing with an external time source).
- Test dependent applications and services (DHCP, file servers, VPN, Exchange, Wi-Fi authentication).
- Take **new system state backups** and update documentation.
- Monitor logs for a week or more before declaring success.

Challenges and Considerations

- **Replication problems:** unhealthy DNS or time sync causes failed replication.
- **Legacy applications** that are hard-coded to old DC names or IPs, or need old protocols (NTLMv1, SMBv1, LDAP simple bind).
- **Service interruption risk:** always have a rollback plan and do the work outside business hours.
- **Functional level and compatibility:** old DCs (for example 2008 R2) cannot coexist with the newest versions; check the supported upgrade paths.
- **FRS to DFSR** migration for SYSVOL.
- **SID history, passwords and trusts** in cross-domain migration; user profiles and permissions need translation.
- **Skills and testing:** try the full process in a **lab / test environment** first.
- **Backup and recovery:** a bad migration may require authoritative restore.
- **Documentation and change management.**

Migrating from 2019 AD to 2022 AD

A practical example of the swing migration, which is the process you perform in the lab.

Important facts

- Windows Server 2019 and 2022 domain controllers can **coexist** in the same domain.
- The highest AD functional level is **Windows Server 2016**. There are **no new functional levels for 2019 or 2022**, so you do not need to raise the level to use 2022 DCs (the existing level only has to meet the minimum documented by Microsoft, and SYSVOL must already replicate with DFSR).

- The schema must be extended to the Windows Server 2022 schema version. This is done automatically during promotion, or manually with adprep.

Step by step

1. **Check the existing DC (2019):** `dcdiag`, `repadmin /replsummary`, `netdom query fsmo`, and take a system state backup.
2. **Build the new server** (Windows Server 2022): install the OS, apply updates, set static IP, set the **DNS to the existing DC**, rename it and join it to the domain.
3. **Install AD DS and DNS roles.**
4. **Promote** the server as an **additional domain controller** in the existing domain. Provide DSRM password, choose DNS and Global Catalog, select the replication source (any DC) and complete the wizard; the server restarts.
5. **Verify replication** and DNS records on the new DC.
6. **Transfer the five FSMO roles** to the 2022 DC (PowerShell or GUI).
7. **Update DNS / DHCP:** change DHCP scope options (DNS servers) to include the new DC; change static DNS settings on servers; update the DNS forwarders and make sure old DC is removed from DNS client settings.
8. **Move other roles** (DHCP, file shares, CA) as required.
9. **Test** for a few days.
10. **Demote the 2019 DC** (remove AD DS role, uncheck the "last domain controller" option; then remove from domain).
11. **Verify again** with `dcdiag`, `repadmin`, and `netdom query fsmo`, and run `gpupdate /force` on a client.
12. **Optional:** change the new DC's IP to the old DC's IP if some devices use hard-coded addresses (only after the old DC is fully removed).

> **Remember:** Always keep **at least two domain controllers** in the domain, and never delete the old DC before replication and FSMO roles are confirmed on the new one.

Project Management

IT professionals such as system administrators rarely only "keep the lights on". Migrations, new server rollouts and upgrades are **projects** and need a structured approach so they finish on time, within budget and with the expected quality.

Projects vs Operations

Point	Project	Operations
Nature	Temporary: has a start and an end	Ongoing, repetitive, continues without end
Purpose	Create a unique product, service or result (change)	Keep the business and systems running (stability)
Output	Something new (new domain controller, new network)	Same output repeatedly (daily backup, user support)
Team	Formed for the project and disbanded after	Permanent teams
Examples	AD migration, data center move, deploying SCCM	Helpdesk, monitoring, patching, backups

Project Life cycle

According to the **PMBOK** (Project Management Institute) approach, every project goes through five process groups:

Phase	What happens	Output
1. Initiation	Define why the project is needed, check feasibility, identify stakeholders and appoint the project manager.	Project charter, business case
2. Planning	Define scope, tasks, schedule, budget, resources, risks, communication and quality plan.	Project plan, WBS, schedule, risk register
3. Execution	Do the work; build, install, configure; manage the team and communicate.	Deliverables (e.g., new servers)
4. Monitoring and Controlling	Track progress vs the plan, control changes, manage risks, quality and cost (runs in parallel with execution).	Status reports, change requests
5. Closing	Hand over to operations, get acceptance, release resources, document lessons learned.	Final report, sign-off, lessons learned

> **Alternative models:** Software and agile teams use iterative cycles (sprints). IT infrastructure projects usually follow the traditional (waterfall) phases above, although many organizations use a hybrid approach.

The Triple Constraint Triangle

Every project is limited by three connected constraints, also called the **Project Management Triangle** or **Iron Triangle**:

- **Scope:** what must be delivered (features, work).
- **Time (schedule):** when it must be finished.
- **Cost (budget):** how much money and resources are available.
- **Quality** sits at the center and depends on balancing the three.

If you change one side, at least one of the others is affected. If the customer adds more work (**scope up**), then you need more **time** or more **cost**, or quality will suffer.

> **Example:** The company wants to migrate 10 servers in 2 weeks with a fixed budget. If management now also asks to migrate 5 more servers (scope increases) without extra time or money, the project will either be late, over budget or poor in quality.

Key Project Roles

Role	Responsibility
Project Sponsor	Provides funding and authority; approves the charter; removes obstacles at the executive level
Project Manager (PM)	Plans, leads and delivers the project; manages scope, time, cost, risk and communication
Stakeholders	Anyone affected by or interested in the project: management, users, customers, vendors
Project team members / Technical leads	Do the technical work (system admins, network engineers, developers)
Business analyst	Gathers and documents requirements
Quality assurance / testers	Verify the result meets requirements
Change Advisory Board (CAB)	Reviews and approves changes to production systems
End users	Use the final result; give feedback and acceptance

Project Manager's Responsibilities

- Define the project scope, objectives and success criteria.

- Build the plan (WBS, schedule, resource and cost estimates).
- Assemble, motivate and lead the team.
- Manage **risks** (identify, analyze, mitigate) and **issues**.
- Control **changes**: every change goes through change control.
- Communicate with stakeholders regularly (status reports, meetings).
- Manage procurement and vendors.
- Track progress, budget and quality; take corrective action.
- Ensure proper documentation, handover and lessons learned.

Active Directory Migration Project

An example of how the project management concepts apply to an AD migration project:

Phase	Activities in the AD migration project
Initiation	Reason: old DCs out of support. Sponsor: IT manager / CIO. Objective: replace Windows Server 2019 DCs with 2022 with no user downtime. Assign PM and technical lead.
Planning	Inventory DCs and dependencies, risk register (replication failure, application breakage), schedule (lab test → pilot → production), resources (servers, licenses), backup and rollback plan, communication plan, change approval from CAB.
Execution	Build and promote new DCs, transfer FSMO, update DNS / DHCP, migrate dependent services, demote old DCs.
Monitoring & Controlling	Daily health checks (`dcdiag`, `repadmin`), track tasks against the schedule, handle incidents and change requests.
Closing	Validation tests, user acceptance, update documentation and diagrams, decommission old servers, lessons learned meeting, handover to operations.

Typical risks

- Replication or DNS failures during the change.
- Legacy applications that break.
- Insufficient testing and no rollback.
- Key staff unavailable; poor communication with users.

Service Level and Operational Level Agreements

When IT provides services to the business (or an external company provides services to a customer), expectations must be written down. **SLAs** and **OLAs** are the documents that do this.

SLA, OLA Key Differences

Point	SLA (Service Level Agreement)	OLA (Operational Level Agreement)
Between	A service provider and an **external customer** (or the business)	**Internal** teams or departments within the same organization (e.g., helpdesk and network team)
Purpose	Defines the level of service the customer will receive	Defines how internal teams support each other to meet the SLA
Legal strength	Often contractual, with penalties	Internal commitment, usually not a legal contract
Example	"Email will be available 99.9% of the time; critical incidents are answered in 30 minutes."	"The network team will respond to helpdesk escalations within 15 minutes."

There is also an **Underpinning Contract (UC)**, which is a contract with an external vendor that supports the service. An OLA supports an SLA internally; a UC supports it externally.

Components of an SLA

- **Service description:** what service is covered (email, VPN, ERP support).
- **Parties and duration:** who signs, start date, review date.
- **Service hours and availability:** for example 24x7 or 8am to 6pm weekdays; target uptime.
- **Performance metrics and targets** (response time, resolution time, availability).
- **Roles and responsibilities** of the provider and the customer.
- **Priority levels and escalation procedures** (P1 critical, P2 high, P3 normal).
- **Reporting and review** frequency.
- **Exclusions:** planned maintenance, customer-caused issues, force majeure.
- **Security, backup and DR commitments.**
- **Penalties / service credits** and remedies for breach.
- **Termination and change** conditions.

SLA / OLA Life cycle

1. **Identify requirements:** understand what the business needs.
2. **Design and negotiate** targets, scope and cost.
3. **Agree and sign** the SLA / OLA.

4. **Implement:** set up tools, processes and teams to meet the targets.
5. **Monitor and measure** performance with tools (monitoring, ticketing).
6. **Report** to the customer regularly.
7. **Review and improve** periodically; revise if the business changes.
8. **Renew or terminate.**

SLA & OLA Metrics

Metric	Meaning
Availability / Uptime %	Percent of time the service is available
Response time	Time to acknowledge a ticket or start working on it
Resolution time	Time taken to fix the incident
MTTR (Mean Time To Repair / Restore)	Average time to restore a service after failure
MTBF (Mean Time Between Failures)	Average time a system works between failures
First Call Resolution (FCR)	Percent of issues solved on the first contact
Ticket backlog / SLA compliance %	Percent of tickets resolved within the target
Customer satisfaction (CSAT)	Survey results from users
RPO / RTO	Data loss and recovery targets (for DR commitments)

What uptime percentages really mean (per year)

Availability	Allowed downtime / year	Allowed downtime / month (approx.)
99%	3.65 days	7.3 hours
99.9% ("three nines")	8.76 hours	43.8 minutes
99.99% ("four nines")	52.6 minutes	4.4 minutes
99.999% ("five nines")	5.26 minutes	26 seconds

Negotiating SLAs and OLAs

- Understand **business priorities** first; do not promise what you cannot deliver.
- Use **realistic, measurable** and clearly defined targets (SMART).
- Base targets on **historical performance data** and the infrastructure capacity (redundancy, staff, support hours).
- Match the cost to the service level: more nines means more cost.
- Define **exclusions** (maintenance windows, third-party failures) clearly.
- Agree how metrics are measured and who reports them.
- Include **escalation** paths and penalties that are fair.
- Involve legal, finance, the technical team and the customer.
- Plan for **review and renegotiation** as the business changes.

SLA Breach Handling

1. **Detect:** monitoring and alerts show that a target will be or has been missed.
2. **Notify and escalate:** inform the service manager and the customer according to the agreement.
3. **Restore service** as the first priority.
4. **Root cause analysis (RCA):** find out why it happened (problem management).
5. **Apply remedies:** service credits, penalties or compensation defined in the SLA.
6. **Corrective and preventive actions:** fix the cause, add redundancy, training, or tools.
7. **Report and review:** include in the regular service review; update the SLA if needed.

Software Licenses

A **software license** is a legal agreement that tells you **how you may use** a piece of software. IT administrators must understand licensing because using software without proper licenses is illegal and can cause big fines in an audit, while buying too many licenses wastes money.

Common license types

License type	Description	Examples
Proprietary / commercial	You pay for the right to use; source code is closed	Windows Server, Microsoft Office, VMware
Open source	Source code available; may be used, modified and shared under conditions (GPL, MIT, Apache, BSD)	Linux, Apache, MySQL, VLC
Freeware	Free to use but source closed and conditions apply	Some utilities
Shareware / trial	Free for a limited time or with limited features	Evaluation versions (for example, Windows Server evaluation)
Subscription (SaaS)	Pay monthly or yearly per user or device; always updated	Microsoft 365, Adobe Creative Cloud
Perpetual	Pay once, use forever (updates may need extra payment)	Older Office versions
OEM	Pre-installed with hardware and tied to that device	Windows on a new laptop
Retail (FPP)	Boxed or single license bought from a store; transferable	Retail Windows license
Volume licensing	Many licenses under a single agreement and key (KMS / MAK)	Microsoft Volume Licensing

Licensing models (how it is counted)

- **Per device** or per user (CAL, Client Access License).
- **Per core / per processor** (Windows Server, SQL Server).
- **Concurrent users:** a fixed number of simultaneous users.
- **Named user vs. site license.**

> **Example: Windows Server** is licensed **per core** (a minimum of 8 core licenses per processor and 16 per server) plus **Client Access Licenses (CALs)** for users or devices that

> connect. **Standard** edition allows 2 virtual machines per fully licensed host, whereas **Datacenter** edition allows unlimited virtual machines.

> **Remember:** Keep a **software asset inventory** (what is installed, where, which license, expiry date) and review it regularly (Software Asset Management, SAM).

SMB vs Enterprise License Agreements

The agreement type depends on the size of the organization. This is explained mainly with Microsoft programs as an example.

Point	SMB (Small and Medium Business)	Enterprise
Organization size	Roughly up to a few hundred users	Large organizations (Microsoft EA typically 500+ users / devices)
Purchase method	Retail, OEM, **CSP (Cloud Solution Provider)** partner subscriptions, Microsoft 365 Business plans, Open / pay-as-you-go	**Enterprise Agreement (EA)**, MPSA, direct contracts with the vendor
Term	Monthly or annual, flexible	Usually 3-year commitments
Cost model	Higher price per unit, no big commitment	Lower price per unit through volume discounts; commit to a volume
Flexibility	Easy to add or remove licenses	Annual **true-up** (pay for growth) and fixed commitment
Management	Self-service portal; simple	Dedicated account managers, license compliance audits, Software Assurance benefits
Extra benefits	Limited	Software Assurance (upgrades, training, hybrid use rights), centralized billing
Compliance risk	Lower complexity but easy to under-license	Complex; needs SAM staff and regular reconciliation

Server Security & Hardening

Hardening Concepts

Server hardening is the process of making a server more secure by **reducing its attack surface**: removing what is not needed, locking down what remains, and configuring everything securely. A default installation of any operating system is built for convenience, not maximum security, so every server should be hardened before it goes into production.

> **Example:** Think of a new house. Hardening means removing extra doors you never use, putting strong locks on the doors you keep, closing unnecessary windows, installing an alarm and keeping a list of who has keys.

Key terms

- **Attack surface:** all the ways an attacker can try to enter (open ports, services, accounts, software).
- **Vulnerability:** a weakness (bug or misconfiguration) in the system.
- **Baseline:** a documented, approved secure configuration for a type of server.
- **Configuration drift:** servers slowly changing away from the baseline; solved by auditing and automation.
- **Defense in depth:** many layers of protection so that if one fails, others still protect.

Frameworks & Benchmarks

Framework / benchmark	Description
CIS Benchmarks (Center for Internet Security)	Detailed, consensus-based, step-by-step secure configuration guides for Windows Server, Linux, databases, network devices. Offers Level 1 (basic, little impact) and Level 2 (stricter) profiles.
Microsoft Security Baselines / Security Compliance Toolkit	Microsoft's recommended GPO settings for Windows Server, with tools such as Policy Analyzer.
DISA STIGs	Security Technical Implementation Guides from the US Department of Defense; very strict.
NIST SP 800-53 / 800-123 / Cybersecurity Framework	US standards for security controls and server security guidance.
ISO/IEC 27001 / 27002	International information security management standard and control catalog.
PCI DSS	Required for systems that store or process payment card data.

Key Hardening Principles & Checklist

Principles

- **Least privilege:** give users and services only the permissions they need.
- **Minimize attack surface:** install only required roles, features and software (Server Core where possible).
- **Secure by default:** change defaults, disable guest and unused accounts.
- **Defense in depth:** firewall + patching + access control + monitoring + backups.
- **Separation of duties and roles:** admins use separate admin accounts.
- **Keep it updated:** patch regularly.
- **Log, monitor and audit** everything important.
- **Fail securely** and **verify** (test and audit the settings).

Hardening checklist (quick view)

Area	Check
Operating system	Latest service pack, updates and security patches installed
Roles and features	Only required roles installed; unused ones removed
Accounts	Default Administrator renamed / protected, Guest disabled, unused accounts removed, strong password policy, MFA for admin access
Network	Host firewall enabled, only needed ports open, unused protocols disabled (SMBv1, LLMNR, NetBIOS where possible)
Services	Unnecessary services stopped and disabled
Remote access	RDP restricted by firewall, **Network Level Authentication**, limited to admin groups; use a jump server / VPN
Encryption	BitLocker for disks, TLS for services, secure protocols only
Logging	Auditing enabled, logs forwarded to central server / SIEM
Malware protection	Antivirus / EDR installed and updated
Backup	Regular tested backups; offline copies
Physical	Server room access control, BIOS password, disable unused ports and boot devices

Server Hardening Practices

Windows Server hardening practices

1. **Install updates** through WSUS / SCCM / Windows Update on a regular schedule; test in a lab first.
2. **Use Server Core** installation when a GUI is not necessary.
3. **Remove unnecessary roles, features and software.**
4. **Apply a security baseline** through Group Policy (CIS or Microsoft baseline).
5. **Account policies:** strong password length, lockout policy, and restrict who can log on locally or by RDP.
6. **Protect administrator accounts:** use separate admin accounts, tiered administration, disable built-in guest, and use **LAPS** (Local Administrator Password Solution) to randomize local admin passwords.
7. **Windows Defender Firewall:** enable on all profiles; allow only required inbound rules.
8. **Disable legacy protocols:** SMBv1, NTLMv1, LLMNR, NetBIOS over TCP/IP (where not needed); require **SMB signing**.
9. **Secure RDP:** enable NLA, change to restricted access, use an RD Gateway or VPN, set account lockout.
10. **Enable auditing** (logon events, account management, policy change, privilege use) and increase event log sizes.
11. **Enable BitLocker** and Secure Boot; protect the BIOS / UEFI with a password.
12. **Control PowerShell:** use logging, Constrained Language Mode and script signing where practical.
13. **Application control:** AppLocker / Windows Defender Application Control.
14. **Run endpoint protection** (Defender or third-party) with real-time scanning and EDR.
15. **Time synchronization** with a trusted NTP source (for Kerberos and logs).
16. **Secure services accounts:** use managed service accounts (gMSA) with the least permissions.
17. **Backups and recovery:** test regularly; protect backup storage.
18. **Vulnerability scanning and periodic audits** to check against the baseline (for example, with the CIS-CAT or Nessus).

Linux server hardening (short)

- Update packages; remove unneeded packages and services.
- Disable root SSH login; use SSH keys and change the default port if needed; use fail2ban.
- Enable the firewall (iptables / nftables / ufw / firewalld) and SELinux / AppArmor.
- Set proper file permissions; enforce sudo with logging.

> **Remember:** Hardening is **not a one-time job**. Re-scan and re-audit regularly, because every new patch, role or configuration change can open a new gap.